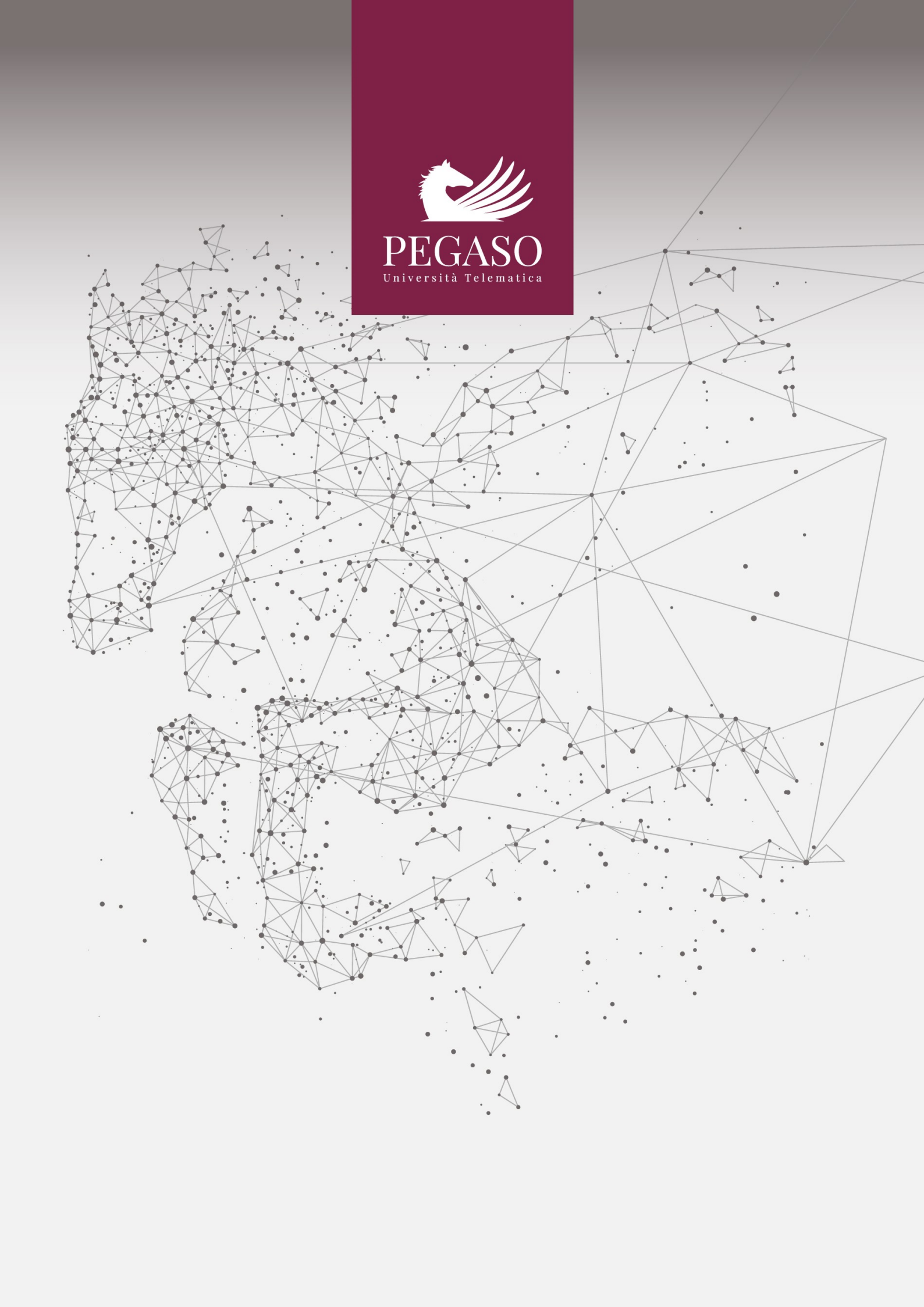

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. AUTENTICAZIONE NELLE APPLICAZIONI WEB 3

2. AUTENTICAZIONE IN HTTP 5

3. ALTRI METODI DI AUTENTICAZIONE 9

BIBLIOGRAFIA 11

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. Autenticazione nelle applicazioni web

Spesso si presenta l'esigenza di dover restringere l'accessibilità di una o più pagine di un'applicazione web a una ristretta cerchia di utenti.

Molti siti sono composti da una parte visibile a tutti i visitatori e da una sezione privata che può essere acceduta soltanto dagli amministratori dell'applicazione attraverso le opportune credenziali di autenticazione.

Quando parliamo di autenticazione, possiamo far riferimento a un accesso privilegiato per alcuni utenti a determinate sezioni di un'applicazione web.

Oggi vengono utilizzati diversi metodi di autenticazione che vanno a sostituire le classiche password che possono risultare scadenti come sicurezza. La tradizionale autenticazione online si affida a qualcosa che si conosce, cioè una password. Questo, però, non è un metodo infallibile, infatti: una password è un dato segreto che va condiviso con chi verifica l'identità. Molto frequentemente non si ha modo di accertare che la propria password venga conservata in modo sicuro e può essere facile preda di chiunque stia osservandone l'inserimento o usando un software come un KeyLogger.

I metodi tramite i quali un essere umano può autenticarsi sono divisi in tre classi, in base a:

- **qualcosa che so** (es. password, frase chiave o numero di identificazione personale (PIN)) si può riferire alla password o ad un'autenticazione pattern-based, per esempio proposta nei sistemi operativi o un'autenticazione basata sul codice PIN, come per i bancomat.
- **qualcosa che ho** (es. tesserino identificativo) è molto spesso un token installato su un dispositivo mobile che si possiede. Esistono due tipologie principali di token mobile:
    - Token che si usano online (challenge / response based)
    - Token che si usano offline (time, sequence o OTP based).
- **qualcosa che sono** (es. impronte digitali, impronta vocale, modello retinico, sequenza del DNA, calligrafia o altri identificatori biometrici) (vedi sistema di riconoscimento biometrico).

La scelta dei diversi metodi di autenticazione è condizionata dai diversi fattori, tra cui l'usabilità, l'importanza delle informazioni da proteggere ed il costo del sistema. Spesso si assiste anche ad una mutua autenticazione in cui ciascuna parte in causa deve autenticarsi all'altra.

Inoltre, spesso, al posto del singolo metodo, viene usata una combinazione di metodi, i.e. un tesserino identificativo e un PIN che ne aumenta la sicurezza. Questa prende il nome di Strong authentication o autenticazione a due fattori.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

È possibile individuare tre tipologie comuni di autenticazione nel web:

- **Basic Authentication**: Il browser visualizza una finestra di che richiede l'inserimento di una username e di una password. Tali credenziali vengono quindi inviate, in formato testo (plain-text), al server in maniera tale che quest'ultimo possa riconoscerle e autenticarle.
- **Digest Authentication**: Si basa sullo stesso processo della Basic Authentication, con la differenza che le credenziali inviate al server vengono convertite, prima dell'invio, in un formato che rappresenta una sorta di impronta digitale delle credenziali stesse.
- **Form-based Authentication**: Utilizza una web form personalizzabile a scelta del programmatore, al posto della finestra di dialogo visualizzata nelle due precedenti tipologie di autenticazione.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Autenticazione in http

Approfondiamo i 2 schemi di Autenticazione per il Protocollo HTTP:

1. Basic Access Authentication
2. Digest Access Authentication

Analizziamo lo scenario della **Basic Access Authentication**.

Il client fa una richiesta (HTTP Request) al server su una risorsa specifica:

GET /www.mybank.it/creditcardcodes.html HTTP/1.1

Il server risponde (http Response) al client dicendogli che non è autenticato:

HTTP/1.1 401 Unauthorized

…

WWW-Authenticate: Basic realm="InternetSecurity"

…

Corpo del messaggio di risposta

Il campo WWW-Authenticate deve indicare, oltre allo schema prescelto (in questo caso: "Basic"), la sfida che è necessario completare per poter accedere alla risorsa richiesta (in questo caso "InternetSecurity"). Il valore della sfida (della challenge) "realm" non verrà allegato alla nuova richiesta prodotta dal client.

A questo punto il client farà una seconda richiesta inviando semplicemente la coppia Username/Password:

GET /www.mybank.it/creditcardcodes.html HTTP/1.1

…

Authorization: Basic QWxhZGRpbjpvcGVuIHNlc2FtZQ==

…

La stringa che compare dopo la parola chiave Basic è ottenuta concatenando quanto digitato dal client e convertito secondo codice radix-64; se ad es. le credenziali dell'utente fossero:

- Nome utente: myusername
- Password: mypassword

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

La concatenazione avviene tramite i due punti: **myusername:mypassword**, pertanto, si deve eseguire la conversione base64 di tale stringa. Se le credenziali sono valide (relative al dominio e alla risorsa richiesta) lo schema di autenticazione è superato con successo.

Tale schema, sebbene semplice, è vulnerabile poiché:

- avviene la trasmissione in chiaro delle credenziali
- avviene la memorizzazione delle credenziali del client sul server http
- è facilmente aggirabile da parte di un hacker che decide di sostituirsi al server HTTP

La **Digest Access Authentication** risolve molti problemi di sicurezza (ma non tutti) che non trovavano soluzione con Basic

Il client fa una richiesta (HTTP Request) al server su una risorsa specifica:

GET /www.mybank.it/creditcardcodes.html HTTP/1.1

Il server risponde (http Response) al client dicendogli che non è autenticato:

HTTP/1.1 401 Unauthorized

…

WWW-Authenticate: Digest

realm="testrealm@host.com",

qop="auth-int",

nonce="dcd98b7102dd2f0e8b11d0f600bfb0c093",

opaque="5ccc069c403ebaf9f0171e9517f40e41"

…

Corpo del messaggio di risposta

La risposta contiene diverse informazioni in più rispetto alla Basic:

- **qop**: stabilisce la "quality of protection"
- **nonce**: è la vera e propria sfida prodotta dal server HTTP (solitamente con algoritmo MD5)
- **opaque**: prodotta dal server e relativa alla specifica risorsa richiesta dal client

Alla ricezione, il client digita le credenziali, produce la risposta alla sfida e richiede nuovamente la risorsa

GET /www.mybank.it/creditcardcodes.html HTTP/1.1

…

WWW-Authenticate: Digest

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

username="myusername",

realm="testrealm@host.com",

qop="auth-int",

nonce="dcd98b7102dd2f0e8b11d0f600bfb0c093",

opaque="5ccc069c403ebaf9f0171e9517f40e41"

uri="/www.mybank.it/creditcardcodes.html",

nc=00000001,

cnonce="0a4f113b",

response="6629fae49393a05397450978507c4ef1",

…

Essendo:

- **cnonce**: valore casuale (contro ogni attacco di tipo "chosen plaintext") e/o meccanismo di mutua autenticazione
- **response**: riporta il digest prodotto dal client HTTP (MD5)
- **realm**, **qop**, **nonce** e **opache** sono i campi che erano stati inviati dal server

Il parametro response è il risultato della operazione (H è una funzione one-way function)

$$H(H(A1) : nonce : nc : cnonce : qop : H(A2))$$

Con:

- $A1 = username : realm : user - password$
- $A2 = Method : uri : H(body)$

In sostanza, il client esegue un **MD5 hash** per creare il parametro response.

Sicuramente il livello di sicurezza è maggiore rispetto alla Basic Access Authentication, ma vi è comunque assenza di riservatezza (il Man in the Middle può intercettare il traffico).

Il digest (o impronta) di un messaggio M è un numero calcolato a partire da questo messaggio e che ha le seguenti proprietà:

- Ha lunghezza fissa che lo rende facile da manipolare e da trasmettere (128 bit)
- È assai improbabile che due messaggi diversi abbiano lo stesso digest
- Non è invertibile, o meglio one-way function (per questo motivo si usa un Hash MD5)

Tale digest è principalmente usato per:

- Verificare l'integrità di un messaggio trasferito
- Autenticazione di un utente con la tecnica del challenge (protocollo HTTP)
- Firma digitale

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Digest access authentication utilizza dunque il protocollo HTTP ed è un'applicazione della funzione crittografica di hash MD5 con utilizzo di un valore nonce per prevenire un replay attack.

In conclusione, **Digest Access Authentication** è meno sicuro rispetto all'autenticazione basata su certificati, ma è comunque più sicuro rispetto all'autenticazione di base poiché le password non vengono inviate in chiaro. Oggi è meno utilizzato rispetto all'autenticazione basata su token (OAuth, JWT) e l'autenticazione basata su certificati (TLS, SSL), tuttavia, alcune implementazioni di software open-source e alcuni sistemi legacy ancora lo utilizzano.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Altri metodi di autenticazione

Tipicamente, si usano metodi più "robusti" per l'autenticazione web-based:

- **Autenticazione Public key** usando un **certificato** client (solitamente usato con HTTPS/SSL client certificate)
- **Autenticazione Kerberos** o SPNEGO, usato per esempio da Microsoft IIS per Integrated Windows Authentication
- **Secure Remote Password** protocol (preferibilmente usato nel layer HTTPS/TLS), anche se non usato nei browser convenzionali
- **OAuth2** authentication (**JSON Web Token** – **JWT** e **Bearer Token**)

Lo standard de facto di autorizzazione per i servizi web è OAuth2, il quale definisce diversi tipi di token. I due "tipi di token" più utilizzati sono JWT e Bearer Token.

Lo standard JWT rappresenta semplicemente un formato di serializzazione di informazioni (claim), espressi in JSON (JavaScript Object Notation). Ogni JWT è composto (a parte casi particolari) da tre parti, codificate in base64url:

- Header
- Payload
- Signature

Nell'header si dichiara il tipo di contenuto del payload e il tipo di algoritmo usato per il calcolo della firma. Tipicamente si usano i seguenti algoritmi:

- RS256 algoritmo asimmetrico, basato su una chiave privata per la generazione della firma e una chiave pubblica per la sua validazione
- HS256 algoritmo simmetrico, nel quale la stessa chiave - condivisa in modo sicuro tra le parti - è usata per generare e validare la firma.

Il Payload o Body contiene i claim che si vogliono trasmettere tra le parti. La Signature è la firma che permette di validare il contenuto del JWT come "non alterato".

Si noti che sia l'header che il payload, se non criptati tramite JSON Web Encryption (JWE), sono perfettamente leggibili da chiunque riesca ad ottenere il JWT che li contiene: di conseguenza è prassi NON inserire informazioni sensibili o segrete nei JWT.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

I Bearer Token sono un tipo particolare di Access Token, usati per ottenere l'autorizzazione ad accedere ad una risorsa protetta da un Authorization Server conforme con lo standard OAuth2.

Non vi è alcun vincolo circa il formato del Bearer Token: esso può essere una stringa esadecimale opaca, incomprensibile al client che la invia, o può essere di tipo "strutturato" come, appunto, i JWT di cui abbiamo brevemente parlato. L'importante è che l'Authorization Server cui è destinato sia in grado di interpretarlo e validarlo correttamente.

Il solo fatto di conoscere il Bearer token, dà la possibilità di accedere alla risorsa.

Facendo un paragone usato spesso e volentieri, il solo fatto di possedere le chiavi (Access Token) di un'auto (Risorsa) dà la possibilità di guidarla. Continuando con il paragone, anche se diverse case automobilistiche usano lo stesso formato per le loro chiavi di avviamento questo non implica che io possa usare la chiave di una Maserati per guidare una Ferrari.

In modo del tutto simile, è importante capire che sebbene quasi tutti gli Authorization Server usino il formato JWT come rappresentazione dei loro Bearer Token, questo non implica affatto che io possa usare i token di uno per accedere alle risorse protette dall'altro.

Ecco quindi spiegata la differenza tra i Bearer Token (autorizzazione) e i JSON Web Token (formato di serializzazione).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- V. Roberto, M. Frailis, A. Gugliotta, P. Omero. Introduzione alle Tecnologie Web, McGraw-Hill, 2010;
- S. Tanembaum. Computer Networks (4 ed.). Prentice Hall (4 ed.), 2003;
- Marco Andreini, Patrizia Andronico, Arianna Del Soldato, Cristian Lucchesi, Maurizio Martinelli, Giuseppe Vasarelli. Manuale corso di Tecnologie Web Istituto di Informatica e Telematica del CNR, 2005.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).